

SHIELD

Screen-level Hiding of Identifiable Elements using Local Detection

An AI agent that reads your screen and never sees your [PASSWORD]

A local model finds every private region and paints it out before anything is transmitted. The cloud model receives meaning without content — and still returns the right action.

WORKING PROTOTYPE



Scan for the
live demo video
[youtu.be/
Buy1x0gCjfc](https://youtu.be/Buy1x0gCjfc)

Built and running

Chrome MV3, today

On-device model

1.1 MB · WebGPU →
WASM

Measured end to end

≈135 ms per pass

PROBLEM STATEMENT ID

SIH26171

PROBLEM STATEMENT TITLE

On-device Visual Perception for
Light-weight Browser Agents

THEME

Smart Automation

PS CATEGORY

Software

TEAM ID

— fill from portal —

TEAM NAME

— as registered —

Today you must choose: **use a screen agent, or keep your screen private.** Shield removes the choice — redaction happens on-device, before transmission, and semantic placeholders keep the meaning the agent needs.

DETAILED EXPLANATION OF THE PROPOSED SOLUTION

- **The user types a plain task** — “log me in”, “fill this form”. Shield captures the visible tab and reads the page’s own structure: 300 elements, viewport-filtered, in 1.6–7.2 ms.
- **A 1.1 MB model runs in the browser** on WebGPU, falling back to WebAssembly. It finds what markup cannot describe — faces, and text baked into images.
- **Both views are redacted together:** pixels painted out of the frame, values replaced by tokens — [PASSWORD], [EMAIL], [ID_NUMBER], [FACE].
- **Only that sealed payload crosses the network.** The model returns one action — click, type or scroll — which the client re-verifies against its own capture before performing, then re-captures and repeats.

HOW IT ADDRESSES THE PROBLEM

- **Meaning survives, content does not.** The model is told a password field is there; it never learns what is in it. A blanket blur would protect the user and break the agent.
- **Privacy is a property of the build, not a policy.** A compile-time type seal, a runtime stage-order guard and a per-request zero-leak sweep. Fail closed: a redaction that fails stops the run rather than sending.
- **Shield stores no credential.** It names the field; the device supplies the value. Nothing to steal from the server, because nothing is there.
- **The user can always check.** An inspector shows the exact bytes that left the machine, and an overlay shows why each region was hidden.

INNOVATION AND UNIQUENESS OF THE SOLUTION

Also unique: one codebase → Chrome (verified) · Edge (same Chromium bundle) · Firefox (generated manifest, port proven up to inference) · and the whole demo runs with no API key and no network.

01

Privacy by construction

Sanitized<T> makes an unredacted payload a compile error, and two further guards catch it at runtime.

02

Redaction that keeps meaning

Semantic placeholders, never a blanket blur. Area painted is 0.72× the area that needed it.

03

Built for Indian identity

Aadhaar with the real Verhoeff check digit, plus PAN, GSTIN, UPI, IFSC, voter ID, DL, passport, bank account and cards.

04

Three verbs, permanently

Click, type or scroll and nothing else — the server can never send code. Injection is bounded by design.

05

Measured, not asserted

Every figure regenerated from a 50-page corpus; every miss published by name. Judges read the payload live.

TECHNOLOGIES TO BE USED

CLIENT · EXTENSION

Chrome Manifest V3, TypeScript, Vite two-pass build
Content script · service worker · offscreen document
Canvas API for pixel redaction; captureVisibleTab

ON-DEVICE AI

ONNX Runtime Web — WebGPU, WebAssembly fallback
UltraFace RFB-320 — 1.1 MB, MIT, WIDER FACE-trained
Tesseract.js OCR, all assets served from the extension

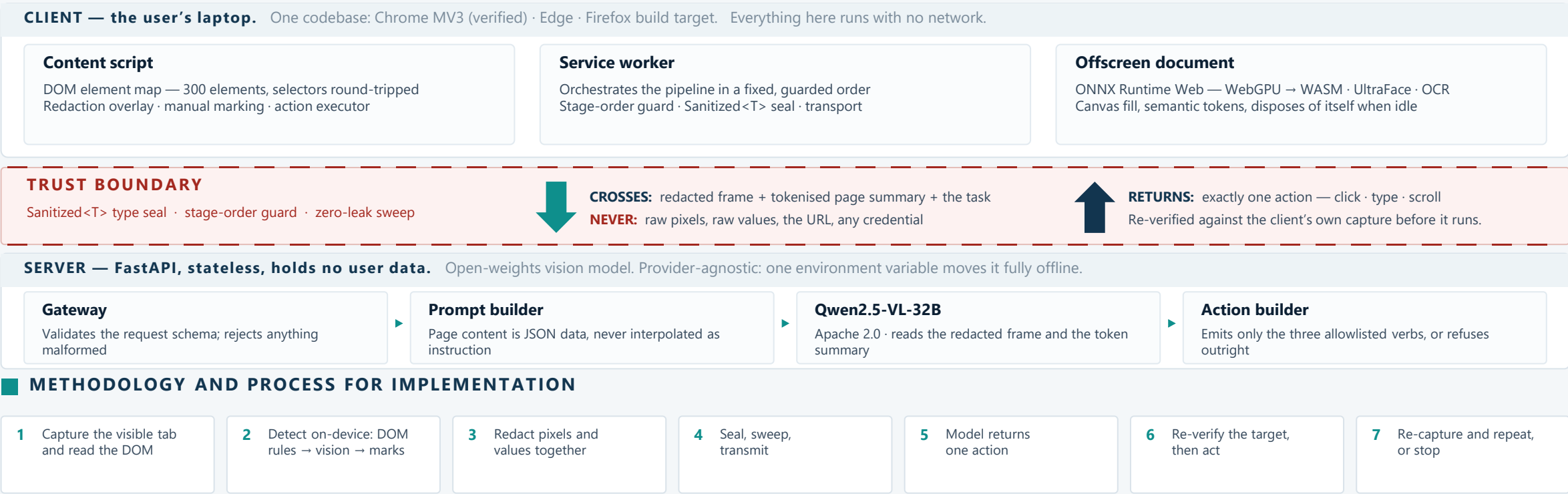
SERVER · REASONING

Python FastAPI — stateless, schema-validated
Qwen2.5-VL-32B-Instruct — Apache 2.0, open weights
Offline: ollama pull qwen2.5vl:7b · rule path needs no key

VERIFICATION

Node native test runner — 419 checks, no framework
npm run benchmark regenerates every number reported
Payload inspector · overlay · per-stage timing

SYSTEM ARCHITECTURE



ANALYSIS OF THE FEASIBILITY OF THE IDEA

Built and running in Chrome today — login autofill, multi-field signup, face redaction, whole-page scan, manual marking. 419 automated checks. Every figure below is regenerated by the benchmark, never typed in by hand.

OFFICIAL METRIC	WEIGHT	WHERE SHIELD STANDS TODAY	STATUS
Accuracy of visual context from screen	25%	DOM map reads a live page in 1.6–7.2 ms with zero unresolved selectors; the pixel reader adds text regions no markup describes. Agreement instrument built — first reading 18.6%.	Measured, 1 page
Recall & precision of PII detection	20%	83.5% recall · 83.5% precision · F1 83.5% over 50 pages and 170 labels, 12 of them captured from live government and banking sites. Every miss listed by name.	Measured
Precision of redaction	20%	83.9% redaction precision. Area painted is 0.72× the area that needed painting — a blanket blur scores near zero here, which is exactly what this metric asks.	Measured
Client-side resource utilisation	20%	Idle: 8 MB JS heap, 0 K GPU. Run peak: 19 MB GPU. CPU never above 1.1%. Heaviest path (whole-page scan) 217 MB — about what one ordinary web page costs, on integrated Intel graphics.	Measured, machine A
End-to-end task latency	15%	≈135 ms per pass — capture 27 · DOM 4 · inference 52 · redaction 40 · round trip 11. The rubric allows “a few seconds”.	Measured

POTENTIAL CHALLENGES AND RISKS

- A miss — something sensitive is not detected and leaves the device.
- Over-redaction — the agent is left with nothing to reason over.
- Names, addresses and amounts written in prose are not detected.
- A hostile page injects instructions into the model’s context.
- No WebGPU, no GPU, or no internet on judging day.

STRATEGIES FOR OVERCOMING THESE CHALLENGES

- Default to hide: an unrecognised filled field is redacted as other. Three independent guards, and a failed redaction stops the run rather than degrading. Misses are published by name, not averaged away.
- Semantic tokens instead of blank boxes, and the painted-versus-needed area ratio is measured on every run (0.72×), so drift in either direction is visible immediately.
- Declared as a known limit rather than discovered by a judge. The whole-page scan and user marking cover it today; a named-entity pass is the next detector, not a redesign.
- Page content reaches the model as JSON data, never as instruction. The allowlist is fixed at three verbs and the client re-verifies the target. Bounded, not eliminated — and we say so.
- Automatic WASM/CPU fallback, proved by a self-test at every start (135 ms init, 17 ms inference). The backend completes the demo with no API key and no network via a rule-based reasoner.

POTENTIAL IMPACT ON THE TARGET AUDIENCE

ISRO, defence and critical infrastructure

Screen automation on terminals where nothing may leave the machine. Open weights under Apache 2.0 and a documented offline path mean no dependency on a foreign hosted API — the reasoning layer stays replaceable and sovereign.

Banking, insurance and telecom

A KYC or account screen can be automated without a customer’s Aadhaar, PAN or card number ever reaching a third-party model. Shield was benchmarked against exactly these pages.

Hospitals, health desks and government offices

Patient and citizen identifiers stay on the terminal. Staff who are forbidden from taking a screenshot get an agent anyway — the policy and the tool stop contradicting each other.

Everyday users, and anyone sharing a screen

AI help without surrendering a password, a face or a home address. The same redaction protects a remote-support session or a recorded call.

BENEFITS OF THE SOLUTION

SOCIAL

The privacy-versus-capability trade-off disappears. The people who most need an assistant — in banking, health and government offices — are exactly the people currently forbidden from using one, and this is the change that lets them.

ECONOMIC

A 1.1 MB model on hardware people already own; no GPU fleet for the private half of the work. The cloud tier only ever receives redacted context, so the expensive model does less and costs less per task.

LEGAL AND REGULATORY

Under the DPDP Act 2023, personal data never reaching a processor is the strongest available position. The audit log is designed to carry categories and counts but never values, so the log does not itself become a liability.

ENVIRONMENTAL AND STRATEGIC

Most screen content never travels: less data transmitted and less cloud inference per task. Open weights and an offline path keep the capability inside the country and inside the building.

0

raw sensitive values transmitted, on any code path — held by three independent guards

83.9%

redaction precision — tight coverage of what matters, not a blanket blur

≈135 ms

the measured cost of privacy, per screen, end to end

1.1 MB

the on-device model that makes all of it possible

The one-line case: every other approach asks you to trust that a server will delete your screen afterwards. Shield never sends it — and lets you read the bytes that prove it.

REGULATION, STANDARDS AND THREAT MODELLING

Digital Personal Data Protection Act, 2023

MeitY. The obligation that makes on-device redaction a requirement rather than a feature.

meity.gov.in/data-protection-framework

UIDAI — Aadhaar numbering and verification

Source of the Verhoeff check digit our Aadhaar rule validates against, so a look-alike number is not flagged.

uidai.gov.in

ISO/IEC 7812-1 — Luhn check

Payment-card validation, used the same way: shape alone is never enough to call something a card number.

OWASP Top 10 for LLM Applications — LLM01

Prompt injection. Shaped the decision to pass page content as data and to cap the action vocabulary at three verbs.

genai.owasp.org/llm-top-10

Microsoft STRIDE threat modelling

The frame our threat model is written in — spoofing, tampering, disclosure, elevation of privilege.

learn.microsoft.com/azure/security

MODELS EVALUATED — LICENCE WAS THE FIRST FILTER

UltraFace RFB-320 — chosen

1.1 MB, MIT, trained on WIDER FACE. Native ONNX, so it runs in the browser with no conversion step.

github.com/Linzaer/Ultra-Light-Fast-Generic-Face-Detector-1MB

WIDER FACE benchmark

The dataset behind that detector, and the reason we state a face-size floor rather than one accuracy number.

shuoyang1213.me/WIDERFACE

Qwen2.5-VL-32B-Instruct — chosen as the reasoner

Apache 2.0, open weights, strong on OCR-heavy tasks. The offline path is the 7B of the same family.

github.com/QwenLM/Qwen2.5-VL · arxiv.org/abs/2502.13923

Microsoft OmniParser — evaluated and rejected

Its icon detector inherits AGPL-3.0 from Ultralytics YOLO, and it is the one stage of that pipeline you cannot skip.

github.com/microsoft/OmniParser · ultralytics.com/license

SmoVLM-256M and Florence-2 — rejected

On output shape, before size was even the question: they emit text, and an element map needs boxes.

RUNTIME, PLATFORM AND OUR OWN ARTEFACTS

ONNX Runtime Web

In-browser inference with a WebGPU execution provider and the WebAssembly fallback we prove by self-test at start-up.

onnxruntime.ai/docs/tutorials/web

W3C WebGPU · Chrome MV3 and the Offscreen API

Why inference lives in an offscreen document: an MV3 service worker can host neither WebAssembly nor WebGPU.

w3.org/TR/webgpu · developer.chrome.com/docs/extensions

Firefox MV3 migration — event pages

The research behind the multi-browser target: Firefox MV3 returns promises from chrome.*, so the client ports unchanged.

extensionworkshop.com/documentation/develop

Tesseract.js

Offline OCR in the browser, reading text baked into images where the DOM has nothing at all to report.

github.com/naptha/tesseract.js

Shield — source, benchmark and decision log

PRD, architecture, STRIDE threat model, the generated benchmark report, the resource protocol and 211 recorded decisions.

github.com/Shiv-Reddy/SHIELD



Working prototype — demo video

youtu.be/Buy1x0gCjfc

Source, full documentation set and the generated benchmark

github.com/Shiv-Reddy/SHIELD